

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 15

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM4-058)

Scenario: A regional water utility is introducing digital billing, customer self-service, and remotely managed meters. Its security program was designed mainly for internal office systems.

What should PRIMARILY guide the revised program objectives?

- A. The new business services, critical information, operational dependencies, obligations, and risks
- B. The preferences of the largest technology supplier
- C. The security products already owned by the utility
- D. The initiatives requiring the fewest business-process changes

Question 2 (CISM4-059)

Scenario: A university's research institutes operate independently and reject central security requirements when they conflict with local practices. No document defines enterprise or institute responsibilities.

Which foundational action should the information security manager take FIRST?

- A. Approve a charter defining scope, decision rights, responsibilities, objectives, and escalation.
- B. Ask external auditors to manage institute compliance.
- C. Publish technical standards before defining authority.
- D. Allow every institute to create an unrelated security program.

Question 3 (CISM4-060)

Scenario: A hotel group acquires a reservation company and plans integration within four months. The current security roadmap schedules identity consolidation and supplier monitoring for the following year.

What is the MOST appropriate roadmap response?

- A. Preserve the current dates because an approved roadmap should never change.
- B. Add every acquisition task without changing resources or other commitments.
- C. Reassess acquisition risk and dependencies, then resequence funded capabilities around the integration milestone.
- D. Delay all integration until the original roadmap is complete.

Question 4 (CISM4-061)

Scenario: A retailer embeds financing from a partner into its checkout process. Customer information moves through both organizations, while each controls different application components.

How should the security program scope be defined?

- A. Limit scope to components directly owned by the retailer.
- B. Assign all customer-information risk to the financing partner.
- C. Exclude the checkout process because responsibility is shared.
- D. Map services, information, risks, interfaces, and responsibilities across both organizations.

Question 5 (CISM4-062)

Which information provides the BEST basis for a secure-development resource plan?

- A. The number of desks available in the security office
- B. A peer company's total security headcount
- C. The development department's current organizational chart
- D. Expected project demand, risk tiers, required services, competencies, automation, and sourcing options

Question 6 (CISM4-063)

Scenario: A pension administrator needs specialized testing of cloud controls twice a year. Its internal assurance team understands business risk but lacks sufficient cloud expertise and capacity.

Which sourcing model is MOST appropriate?

- A. Co-source defined testing with qualified specialists while retaining internal scope, accountability, review, and knowledge transfer.
- B. Transfer ownership of control effectiveness to the external specialists.
- C. Cancel cloud-control testing until an entirely internal team can be hired.
- D. Ask control operators to approve their own assurance conclusions.

Question 7 (CISM4-064)

Scenario: An agricultural cooperative can fund either several isolated tool upgrades or a shared identity foundation needed by multiple approved program initiatives. The foundation costs more initially but eliminates duplicated processes.

Which analysis should drive the budget decision?

- A. Fund requests in the order departments submitted them.
- B. Select the option containing the greatest number of products.
- C. Compare enterprise risk reduction, capability dependencies, business benefits, implementation feasibility, and lifecycle cost.
- D. Choose the lowest initial purchase price without considering future operations.

Question 8 (CISM4-065)

Scenario: A media company has strong security operations but limited privacy engineering and architecture governance skills. Both capabilities are required for a new personalized-content service.

Which workforce action should the manager take FIRST?

- A. Provide the same introductory course to the entire security team.
- B. Assign the missing governance responsibilities to internal audit.
- C. Hire only for the role with the highest market salary.
- D. Map capacity needs to development, recruitment, succession, and external support.

Question 9 (CISM4-066)

Which role normally determines the business sensitivity and classification of a customer dataset?

- A. The database administrator
- B. The accountable information owner
- C. The backup service provider
- D. The independent auditor

Question 10 (CISM4-067)

Which inventory content MOST supports risk-based information protection?

- A. Only the purchase date of storage hardware
- B. Only assets physically located in corporate buildings
- C. A single generic owner assigned to every dataset
- D. Business purpose, accountable owner, classification, location, dependencies, and lifecycle status

Question 11 (CISM4-068)

Scenario: An engineering company uses classification labels, but employees transfer restricted designs between subsidiaries using inconsistent methods because no exchange requirements are defined.

What is the MOST appropriate program improvement?

- A. Remove classification labels from intercompany transfers.
- B. Embed classification-based access, transfer, retention, and disposal rules in exchange workflows.
- C. Require the security manager to approve every individual file transfer.
- D. Measure only the number of files labeled restricted.

Question 12 (CISM4-069)

Scenario: A loan company retires a legacy application but preserves its database indefinitely on an unmanaged server. The application owner left, access remains active, and retention requirements are unclear.

Which action should occur FIRST?

- A. Delete the database immediately without checking obligations.
- B. Leave the database unchanged because the application is retired.
- C. Assign ownership, determine retention needs, restrict access, and plan disposition.
- D. Allow the server administrator to choose a permanent retention period.

Question 13 (CISM4-070)

Which statement about security frameworks is MOST accurate?

- A. A framework transfers security accountability to its publisher.
- B. A framework makes organizational risk assessment unnecessary.
- C. A framework mandates identical controls for all enterprises.
- D. A framework provides structured guidance tailored to organizational context.

Question 14 (CISM4-071)

What is the BEST basis for prioritizing outcomes from an adopted framework?

- A. The alphabetical order of framework sections
- B. Organizational risk, business objectives, obligations, dependencies, and current capability gaps
- C. The preferences of the framework implementation consultant
- D. The practices already supported by current tools

Question 15 (CISM4-072)

Scenario: A business services provider answers similar security requirements separately for major customers and its internal framework. Control owners repeat the same testing and evidence collection each quarter.

Which action would BEST reduce duplication without losing accountability?

- A. Create a separate operating control for every contractual sentence.
- B. Ignore customer requirements that resemble internal controls.
- C. Map requirements to a governed common control set and evidence repository while retaining customer-specific traceability.
- D. Use one customer's requirements as a substitute for all others without analysis.

Question 16 (CISM4-073)

Which document should express management's mandatory direction and intent for information security?

- A. Guideline
- B. Policy
- C. Procedure
- D. Test script

Question 17 (CISM4-074)

Where should mandatory minimum encryption requirements that support policy normally be documented?

- A. In an approved security standard
- B. In a business continuity exercise record
- C. In an operator's informal notes
- D. In an optional guideline

Question 18 (CISM4-075)

Scenario: A warehouse system cannot support the new privileged-access standard until a replacement arrives in six months. Operations proposes enhanced logging during the interim.

What should the manager require before the exception is authorized?

- A. Removal of all warehouse systems from the standard
- B. Informal approval by the system administrator
- C. Risk, ownership, compensating controls, monitoring, review conditions, and expiration.
- D. Evidence that the system has never experienced an incident

Question 19 (CISM4-076)

Scenario: Several offices created local onboarding procedures that conflict with the enterprise access standard. The variations were not approved and produce different levels of access verification.

Which response should the information security manager take FIRST?

- A. Assess each variation's need and risk, then govern approval or retirement.
- B. Allow local procedures to override the standard automatically.
- C. Remove the enterprise standard because local practices differ.
- D. Ask internal audit to become the procedure owner.

Question 20 (CISM4-077)

Scenario: A global manufacturer is creating a shared enterprise data platform. Business domains use incompatible access and protection models, and the target enterprise architecture expects reusable data services.

Which architecture action should occur FIRST?

- A. Require every domain to purchase the same security product.
- B. Define security principles and capabilities aligned with target architecture and risk.
- C. Let each project set unrelated security principles.
- D. Wait until all data has migrated before defining requirements.

Question 21 (CISM4-078)

Scenario: A logistics company approves a target security architecture that assumes reliable device identity and centralized telemetry. Its current fleet lacks both capabilities, and replacement will take three years.

What should the architecture roadmap contain?

- A. Only a diagram of the final target state
- B. A requirement to complete all changes immediately regardless of fleet availability
- C. A current-to-target gap analysis with dependencies, transition states, interim safeguards, priorities, and measurable milestones
- D. Separate permanent architectures for each vehicle model

Question 22 (CISM4-079)

Scenario: A healthcare provider must restrict cross-border access to certain records. Architecture diagrams show regional services, but reviewers cannot determine how the restriction is enforced or verified.

Which artifact should the manager request?

- A. Traceability from the access requirement to architecture decisions, control responsibilities, data flows, and acceptance evidence
- B. A larger inventory of server model numbers
- C. A statement that regional services are commonly used in the industry
- D. A transfer of architecture approval to the service provider

Question 23 (CISM4-080)

Scenario: A financial technology company reviews solution architecture only after development. Teams repeatedly request exceptions because core designs are already committed.

Which governance change would BEST reduce late exceptions?

- A. Prohibit every architecture exception regardless of business need.
- B. Require internal audit to design application security.
- C. Embed early risk-tiered architecture checkpoints with an approved exception path.
- D. Review only solutions that have already experienced incidents.

Question 24 (CISM4-081)

Scenario: A national retailer can centralize key security services in one rapid migration or use regional stages. The rapid plan reaches consistency sooner but creates a high-impact cutover; staging requires temporary interoperability controls.

How should the security manager evaluate the alternatives?

- A. Choose the fastest plan because transition speed is the only architecture objective.
- B. Compare risk reduction, cutover resilience, dependencies, interim controls, business impact, lifecycle cost, and success criteria.
- C. Keep the current fragmented services indefinitely.
- D. Allow regions to adopt unrelated permanent target states.

Question 25 (CISM4-082)

Which metric BEST reflects the outcome of a critical-supplier oversight program?

- A. Number of questionnaire fields sent to suppliers
- B. Critical suppliers with current risk decisions and timely material remediation.
- C. Hours spent configuring the supplier portal
- D. Number of procurement meetings attended by security

Question 26 (CISM4-083)

Scenario: The percentage of timely access removals has declined for four months. The dashboard shows one global total and no information about request sources, systems, owners, or delay causes.

Which additional analysis would MOST support corrective action?

- A. Trends by risk tier, process, owner, backlog age, and root cause.
- B. The number of colors used in the dashboard
- C. The total number of security employees
- D. The number of executives who opened the report

Question 27 (CISM4-084)

Scenario: A global charity is told to raise every security capability to the highest maturity level. Funding the proposal would displace essential mission projects.

Which maturity recommendation should the information security manager make?

- A. Stop using maturity information in program decisions.
- B. Approve maximum maturity because it guarantees acceptable residual risk.
- C. Fund only the capabilities with the lowest current scores.
- D. Set capability targets based on risk, mission dependence, outcomes, and value.

Question 28 (CISM4-085)

What is the MOST important basis for evaluating a proposed control design?

- A. Whether it addresses the objective and risk within operating requirements.
- B. Whether a competitor selected the same product
- C. Whether the control is the most restrictive available
- D. Whether the control uses a fashionable technology

Question 29 (CISM4-086)

Scenario: A benefits administrator proposes lengthy identity checks for every caller. The checks reduce impersonation risk but would prevent timely service to customers with accessibility needs.

Which action should the security manager take?

- A. Approve the longest process because more steps always mean less total risk.
- B. Evaluate alternative verification controls against impersonation risk, accessibility, service requirements, and exception governance.
- C. Allow agents to skip verification whenever queues are long.
- D. Remove identity verification from all customer calls.

Question 30 (CISM4-087)

Scenario: A law firm restricts access to case files in its document system. Authorized users can still export files to unmanaged locations, a path included in the approved risk scenario.

Which management response BEST addresses the gap?

- A. Accept the control set because repository access is restricted.
- B. Increase repository password length without addressing exports.
- C. Reassess end-to-end coverage and add safeguards for export and disposal.
- D. Ask internal audit to operate export controls.

Question 31 (CISM4-088)

Scenario: A marketplace can reduce fraudulent seller changes through a fully manual approval process or layered automated checks with targeted human review. Both meet minimum requirements but differ in scale and failure modes.

Which evaluation approach is MOST appropriate?

- A. Choose the design with the greatest number of individual checks.
- B. Compare risk coverage, error consequences, scalability, resilience, maintainability, user impact, and total cost.
- C. Choose the lowest implementation cost regardless of ongoing operations.
- D. Select the option recommended by the first vendor consulted.

Question 32 (CISM4-089)

Scenario: A pharmaceutical company configures quarterly access reviews for trial data. The tool works, but reviewers have not been appointed and no process exists for disputed or overdue decisions.

What must happen before the control is declared implemented?

- A. The vendor must confirm software installation.
- B. Establish reviewers, procedures, escalation, training, dependencies, and acceptance evidence.
- C. Internal audit must perform all quarterly reviews.
- D. The project must spend its remaining budget.

Question 33 (CISM4-090)

Scenario: A hospital invites security to review connected-building systems only after construction contracts are signed. Required network separation then creates expensive redesign.

Which program change would MOST improve future projects?

- A. Embed risk-tiered requirements and reviews throughout the project lifecycle.
- B. Require security to own every facilities decision.
- C. Approve projects automatically when construction deadlines are fixed.
- D. Perform a longer security review after construction is complete.

Question 34 (CISM4-091)

Scenario: An advertising agency launches an approved client-sharing service, but employees continue using personal accounts. Interviews show the approved service cannot share large files and client onboarding takes several days.

Which initial response is MOST appropriate?

- A. Report success because the approved service is available.
- B. Analyze adoption barriers, correct the workflow, and manage interim risk.
- C. Discipline every user before addressing service limitations.
- D. Send more reminders without examining the workflow.

Question 35 (CISM4-092)

Scenario: A construction group pilots device restrictions at headquarters. The pilot succeeds, but remote sites use intermittent connections, local support is untrained, and offline behavior has not been tested.

Which deployment decision is BEST?

- A. Validate remote-site conditions, support readiness, acceptance criteria, and rollback, then expand in controlled phases.
- B. Deploy everywhere immediately because headquarters testing passed.
- C. Cancel the control because the first pilot was not universal.
- D. Allow each site to decide whether restrictions are necessary.

Question 36 (CISM4-093)

Scenario: A property company requires approval before vendors receive building access. Existing testing confirms that forms exist but not that the vendor population is complete or approvals precede access.

What should the revised test include?

- A. Only confirmation that the access policy is published
- B. A count of emails sent by the access system
- C. Population completeness, approval authority and timing, access alignment, exceptions, and evidence of removal
- D. The control operator's general opinion of effectiveness

Question 37 (CISM4-094)

Scenario: Testing finds one identity-data defect affecting dozens of critical applications and several isolated documentation errors in low-impact services. The finding system assigns all items the same due date.

How should remediation be prioritized?

- A. By exposure, systemic reach, root cause, dependencies, and sustainable correction.
- B. By the alphabetical order of affected applications
- C. By applying identical deadlines regardless of impact
- D. By the personal preferences of finding owners

Question 38 (CISM4-095)

Which arrangement creates the GREATEST threat to assurance independence?

- A. Internal audit considers management testing when planning separate assurance work.
- B. A control owner monitors performance each month.
- C. An independent reviewer asks the operator to explain evidence.
- D. The control operator performs testing and approves its own effectiveness conclusion.

Question 39 (CISM4-096)

Scenario: A retailer calls a transaction-monitoring control effective because the rule set was approved at launch. No evidence covers later rule changes, alert disposition, system coverage, or outcome trends.

What conclusion should the information security manager reach?

- A. Launch approval proves the control remained effective.
- B. Automated controls need no evidence after implementation.
- C. Require evidence of design, change control, operation, exceptions, and outcomes.
- D. Effectiveness should be evaluated only after a financial loss.

Question 40 (CISM4-097)

Which outcome BEST demonstrates an effective security awareness program?

- A. More pages are added to the annual presentation.
- B. Every employee receives identical technical content.
- C. The security team sends a larger number of reminders.
- D. Targeted security behaviors improve and associated risk indicators decline.

Question 41 (CISM4-098)

Scenario: Accounts-payable staff complete general security training, but approvers still accept urgent bank-detail changes without independent verification.

Which training change is MOST appropriate?

- A. Provide scenario-based role training and decision-time reinforcement for payment changes, then measure verification behavior.
- B. Increase the length of general training for every employee.
- C. Replace training with an annual policy acknowledgement.
- D. Limit training to approvers who have already made an error.

Question 42 (CISM4-099)

Scenario: A hotel chain reports high awareness-course completion, but guest-data handling errors remain concentrated among seasonal reception staff during check-in peaks.

Which action would BEST improve the awareness program?

- A. Declare success based solely on course completion.
- B. Address peak-workflow drivers, reinforce seasonal staff, and measure representative behavior.
- C. Stop collecting behavioral data because results vary by workforce group.
- D. Repeat identical training across all roles without investigating the cause.

Question 43 (CISM4-100)

Scenario: A legal publisher plans to outsource manuscript production containing confidential author information. Procurement has reviewed cost but not security controls or service termination.

Which requirement set should security recommend?

- A. A general confidentiality clause as the only safeguard
- B. Approval based solely on the provider's market reputation
- C. Transfer of information ownership to the production provider
- D. Risk-based diligence, security duties, monitoring, supplier governance, continuity, and exit terms.

Question 44 (CISM4-101)

Scenario: Four customer-facing providers use the same identity-verification subcontractor. Each direct provider met onboarding requirements, but simultaneous dependency failure has not been assessed.

Which fourth-party action should the information security manager take FIRST?

- A. Assume separate provider approvals address the shared dependency.
- B. Wait for a subcontractor outage before changing oversight.
- C. Assess aggregate business impact, concentration, resilience, contractual visibility, alternatives, and monitoring needs.
- D. Take direct operational control of the subcontractor's systems.

Question 45 (CISM4-102)

Scenario: A nonprofit is replacing its donor-management provider. Data can be exported, but attachments, audit history, user entitlements, verified deletion, and transition support are not addressed.

Which exit approach is BEST?

- A. Terminate immediately and reconstruct missing information afterward.
- B. Keep both providers indefinitely.
- C. Rely on a verbal assurance that remaining data will be protected.
- D. Test data migration, continuity, access revocation, deletion evidence, and acceptance.

Question 46 (CISM4-103)

Scenario: A security steering committee receives hundreds of operational statistics but cannot tell which program objectives are threatened or what action members should take.

How should the dashboard be redesigned?

- A. Report only work performed directly by the security team.
- B. Add every underlying event record for committee analysis.
- C. Remove unfavorable results until remediation is complete.
- D. Show outcome and risk trends, business impact, decisions, owners, and actions.

Question 47 (CISM4-104)

Scenario: A business unit's critical control remains below target beyond its approved remediation date. The residual exposure exceeds tolerance, and the security manager cannot accept it.

Which escalation response is MOST appropriate?

- A. Extend the target so the issue no longer appears overdue.
- B. Accept the exposure on behalf of the business owner.
- C. Escalate through the defined path with evidence, impact, accountability, alternatives, and the decision required.
- D. Omit the issue until remediation is finished.

Question 48 (CISM4-105)

Scenario: A distribution company plans a security change affecting warehouse productivity. Operations leaders resist because they were shown a completed design rather than involved in defining requirements.

Which engagement approach would BEST improve the outcome?

- A. Define risk and operational outcomes, alternatives, decisions, and measures jointly.
- B. Require operations to implement the completed design without review.
- C. Transfer all security risk decisions to warehouse supervisors.
- D. Cancel the security objective to avoid disagreement.

Question 49 (CISM4-106)

Scenario: A financial cooperative delegates customer onboarding to local branches. Existing controls and metrics assume a centralized team and do not identify branch accountability.

Which program-maintenance action should the information security manager take FIRST?

- A. Keep centralized procedures unchanged because the control objective is stable.
- B. Exclude branch onboarding from the security program.
- C. Wait for errors before revising program processes.
- D. Assess workflows, ownership, risk, and capacity, then update the program.

Question 50 (CISM4-107)

Scenario: A warehouse company wants autonomous robots to use operational maps and inventory data. Safety interfaces, supplier access, network dependencies, and existing control coverage are not yet understood.

Which program approach is MOST appropriate?

- A. Permit unrestricted deployment until a security event occurs.
- B. Assess use cases, set supplier guardrails, run a pilot, and update controls.
- C. Ban robotics permanently because current standards do not mention it.
- D. Let each warehouse create unrelated security requirements.

Answer Key

Domain III - Information Security Program

1 A	2 A	3 C	4 D	5 D
6 A	7 C	8 D	9 B	10 D
11 B	12 C	13 D	14 B	15 C
16 B	17 A	18 C	19 A	20 B
21 C	22 A	23 C	24 B	25 B
26 A	27 D	28 A	29 B	30 C
31 B	32 B	33 A	34 B	35 A
36 C	37 A	38 D	39 C	40 D
41 A	42 B	43 D	44 C	45 D
46 D	47 C	48 A	49 D	50 B

Detailed Explanations

Question 1 (CISM4-058)

Correct answer: A - The new business services, critical information, operational dependencies, obligations, and risks

The revised objectives should address the utility's new services, information, dependencies, obligations, and exposure. Existing products and supplier preferences are secondary inputs, while avoiding process change can leave material risk untreated.

Question 2 (CISM4-059)

Correct answer: A - Approve a charter defining scope, decision rights, responsibilities, objectives, and escalation.

An approved charter establishes the mandate and shared-accountability model needed to govern autonomous institutes. Standards require underlying authority, auditors should remain independent, and unrelated programs would deepen inconsistency.

Question 3 (CISM4-060)

Correct answer: C - Reassess acquisition risk and dependencies, then resequence funded capabilities around the integration milestone.

The acquisition changes exposure and capability timing, so the roadmap should be reassessed and transparently resequenced. Freezing the plan, adding unsupported work, or delaying the business indefinitely fails to balance risk and delivery realities.

Question 4 (CISM4-061)

Correct answer: D - Map services, information, risks, interfaces, and responsibilities across both organizations.

Program scope should follow the end-to-end business service and information risk, with clear responsibilities at organizational boundaries. Ownership limits and shared responsibility do not remove exposure, and enterprise accountability cannot be fully transferred to the partner.

Question 5 (CISM4-062)

Correct answer: D - Expected project demand, risk tiers, required services, competencies, automation, and sourcing options

A resource plan should connect anticipated demand and risk to services, skills, tooling, and delivery models. Office space, reporting lines, and peer headcount may provide context but do not define the organization's capability needs.

Question 6 (CISM4-063)

Correct answer: A - Co-source defined testing with qualified specialists while retaining internal scope, accountability, review, and knowledge transfer.

Co-sourcing can provide competence and capacity while internal management retains accountability, scope, and review and builds knowledge. External help does not transfer ownership, delay leaves an assurance gap, and operator self-approval weakens objectivity.

Question 7 (CISM4-064)

Correct answer: C - Compare enterprise risk reduction, capability dependencies, business benefits, implementation feasibility, and lifecycle cost.

Portfolio funding should consider risk reduction, shared dependencies, value, feasibility, and total cost, which exposes the foundation's enterprise impact. Product count, submission order, and initial price alone are not decision-quality criteria.

Question 8 (CISM4-065)

Correct answer: D - Map capacity needs to development, recruitment, succession, and external support.

A competency plan connects defined capability needs to appropriate workforce options and timing. Generic training is not targeted, salary does not establish priority, and internal audit should not operate missing management capabilities.

Question 9 (CISM4-066)

Correct answer: B - The accountable information owner

The information owner has the business accountability to determine sensitivity and classification. Administrators and providers act as custodians, while auditors assess whether ownership and classification are properly governed.

Question 10 (CISM4-067)

Correct answer: D - Business purpose, accountable owner, classification, location, dependencies, and lifecycle status

Business purpose, ownership, sensitivity, location, dependencies, and lifecycle state enable informed protection and disposition. Hardware purchases and physical location are incomplete, while generic ownership defeats accountability.

Question 11 (CISM4-068)

Correct answer: B - Embed classification-based access, transfer, retention, and disposal rules in exchange workflows.

Classification becomes useful when it drives clear lifecycle handling rules embedded in actual workflows. Removing labels hides risk, central approval will not scale, and label counts do not demonstrate proper handling.

Question 12 (CISM4-069)

Correct answer: C - Assign ownership, determine retention needs, restrict access, and plan disposition.

Retired-system information remains subject to ownership, retention, protection, and disposition requirements. Immediate deletion could violate obligations, inaction preserves exposure, and an administrator lacks authority to make the business retention decision alone.

Question 13 (CISM4-070)

Correct answer: D - A framework provides structured guidance tailored to organizational context.

Frameworks provide organized guidance but require contextual selection and tailoring. They do not transfer accountability, replace risk assessment, or prescribe an identical control design for every organization.

Question 14 (CISM4-071)

Correct answer: B - Organizational risk, business objectives, obligations, dependencies, and current capability gaps

Tailoring should direct effort to the outcomes most relevant to the organization's risks, objectives, obligations, dependencies, and gaps. Publication order, tool convenience, and consultant preference do not provide a defensible priority basis.

Question 15 (CISM4-072)

Correct answer: C - Map requirements to a governed common control set and evidence repository while retaining customer-specific traceability.

A common control and evidence model supports reuse while preserving traceability to each obligation. Ignoring or assuming equivalence can create gaps, while separate controls for every sentence create unnecessary duplication.

Question 16 (CISM4-073)

Correct answer: B - Policy

Policy communicates mandatory management direction and intent. Procedures describe execution, guidelines recommend approaches, and test scripts define assurance steps rather than enterprise direction.

Question 17 (CISM4-074)

Correct answer: A - In an approved security standard

An approved standard contains specific mandatory requirements supporting policy. Guidelines are advisory, exercise records provide evidence, and informal notes lack the authority and governance of a standard.

Question 18 (CISM4-075)

Correct answer: C - Risk, ownership, compensating controls, monitoring, review conditions, and expiration.

A valid exception is explicitly risk-assessed, approved by the proper authority, protected, monitored, and time-limited. Broad exclusion and informal operator approval bypass governance, while incident history does not establish acceptable future risk.

Question 19 (CISM4-076)

Correct answer: A - Assess each variation's need and risk, then govern approval or retirement.

The manager should determine whether legitimate local requirements exist, then restore authorized alignment and traceability. Automatic override and standard removal abandon governance, while internal audit should assess rather than own operating procedures.

Question 20 (CISM4-077)

Correct answer: B - Define security principles and capabilities aligned with target architecture and risk.

Aligned principles and capabilities provide coherent guidance for reusable data services before project choices become fixed. Product uniformity does not guarantee architecture fit, independent principles create fragmentation, and waiting makes redesign likely.

Question 21 (CISM4-078)

Correct answer: C - A current-to-target gap analysis with dependencies, transition states, interim safeguards, priorities, and measurable milestones

A usable roadmap must explain how to move from current limitations to the target while governing transitional exposure and dependencies. A target diagram alone is insufficient, immediate change may be infeasible, and permanent model-specific designs perpetuate fragmentation.

Question 22 (CISM4-079)

Correct answer: A - Traceability from the access requirement to architecture decisions, control responsibilities, data flows, and acceptance evidence

Traceability demonstrates how the requirement is translated into design, ownership, information flow, and verifiable controls. Hardware detail and industry popularity do not establish compliance, and the organization retains architecture governance.

Question 23 (CISM4-080)

Correct answer: C - Embed early risk-tiered architecture checkpoints with an approved exception path.

Early, tiered checkpoints and reusable patterns make conformance practical while retaining accountable exceptions. A total ban is inflexible, audit should remain independent, and incident-based selection is reactive and incomplete.

Question 24 (CISM4-081)

Correct answer: B - Compare risk reduction, cutover resilience, dependencies, interim controls, business impact, lifecycle cost, and success criteria.

A sound roadmap decision weighs target benefits against transition risk, resilience, dependencies, business impact, total cost, and measurable completion. Speed alone is inadequate, indefinite delay preserves weakness, and unrelated targets defeat consistency.

Question 25 (CISM4-082)

Correct answer: B - Critical suppliers with current risk decisions and timely material remediation.

Current risk decisions, monitored obligations, and timely remediation indicate whether critical suppliers are actually governed. Questionnaire size, configuration effort, and meeting attendance are activity measures rather than outcome evidence.

Question 26 (CISM4-083)

Correct answer: A - Trends by risk tier, process, owner, backlog age, and root cause.

Segmented trends identify where significant delays occur, who can act, and what constraints or causes require correction. Dashboard appearance, total staffing, and report views do not explain the operational failure.

Question 27 (CISM4-084)

Correct answer: D - Set capability targets based on risk, mission dependence, outcomes, and value.

Target maturity should be proportionate to mission needs, risk, outcomes, and economics rather than uniformly maximal. Maximum maturity does not guarantee acceptable risk, low scores alone do not determine value, and maturity remains a useful decision input.

Question 28 (CISM4-085)

Correct answer: A - Whether it addresses the objective and risk within operating requirements.

Control design must be traceable to the intended objective and risk and fit relevant requirements and business conditions. Fashion, competitor choice, and maximum restriction do not demonstrate suitability or effectiveness.

Question 29 (CISM4-086)

Correct answer: B - Evaluate alternative verification controls against impersonation risk, accessibility, service requirements, and exception governance.

The control must reduce impersonation risk while supporting accessibility and service needs through a governed design. More steps can create business harm, discretionary bypass is inconsistent, and eliminating verification abandons the objective.

Question 30 (CISM4-087)

Correct answer: C - Reassess end-to-end coverage and add safeguards for export and disposal.

The control set must cover the full risk path after export, not only repository access. Password changes do not address authorized export, and internal audit should independently assess controls rather than operate them.

Question 31 (CISM4-088)

Correct answer: B - Compare risk coverage, error consequences, scalability, resilience, maintainability, user impact, and total cost.

A balanced comparison considers risk coverage and how each strategy performs, fails, scales, affects users, and costs over time. Check count, vendor preference, and initial cost alone cannot establish the better control strategy.

Question 32 (CISM4-089)

Correct answer: B - Establish reviewers, procedures, escalation, training, dependencies, and acceptance evidence.

Implementation includes operating ownership, procedures, competence, escalation, integration, and validated readiness, not just configured technology. Audit should not operate the control, while installation and budget use do not prove effective operation.

Question 33 (CISM4-090)

Correct answer: A - Embed risk-tiered requirements and reviews throughout the project lifecycle.

Lifecycle integration lets requirements influence design and contracts when change remains feasible. Larger late reviews preserve the root problem, security should not own facilities, and fixed deadlines do not justify automatic approval.

Question 34 (CISM4-091)

Correct answer: B - Analyze adoption barriers, correct the workflow, and manage interim risk.

The program should correct the size and onboarding barriers preventing intended operation while governing interim exposure. Availability alone is not adoption, reminders do not fix unusable design, and punishment before remediation ignores the root cause.

Question 35 (CISM4-092)

Correct answer: A - Validate remote-site conditions, support readiness, acceptance criteria, and rollback, then expand in controlled phases.

A controlled rollout should extend evidence to representative operating conditions and confirm support and recovery readiness. Immediate deployment overgeneralizes the pilot, cancellation discards a viable control, and local discretion weakens consistent risk treatment.

Question 36 (CISM4-093)

Correct answer: C - Population completeness, approval authority and timing, access alignment, exceptions, and evidence of removal

The revised test should examine complete coverage and whether authorization, access, exceptions, and removal operate as intended. Policy publication, email volume, and operator opinion do not provide sufficient operating evidence.

Question 37 (CISM4-094)

Correct answer: A - By exposure, systemic reach, root cause, dependencies, and sustainable correction.

Risk and systemic reach should focus attention on the shared defect while accounting for dependencies and sustainable correction. Alphabetical order, uniform deadlines, and personal preference do not reflect exposure or business impact.

Question 38 (CISM4-095)

Correct answer: D - The control operator performs testing and approves its own effectiveness conclusion.

Having the operator control sample selection, testing, and approval creates a direct self-review threat. Owner monitoring is expected, independent reviewers may seek explanations, and audit may consider management work while retaining its own judgment.

Question 39 (CISM4-096)

Correct answer: C - Require evidence of design, change control, operation, exceptions, and outcomes.

Point-in-time design approval does not prove complete, current, and sustained operation. Automation still requires assurance, and waiting for loss would replace proactive evaluation with failure-driven evidence.

Question 40 (CISM4-097)

Correct answer: D - Targeted security behaviors improve and associated risk indicators decline.

Improved relevant behavior and declining human-risk indicators demonstrate the intended outcome. Presentation size, uniform content, and message volume are activities that do not establish effective decisions or risk reduction.

Question 41 (CISM4-098)

Correct answer: A - Provide scenario-based role training and decision-time reinforcement for payment changes, then measure verification behavior.

Role scenarios and workflow reinforcement address the specific high-risk decision and enable behavioral measurement. Longer generic content and acknowledgement remain indirect, while waiting for errors is reactive and incomplete.

Question 42 (CISM4-099)

Correct answer: B - Address peak-workflow drivers, reinforce seasonal staff, and measure representative behavior.

The segmented evidence identifies a specific workforce and operating context for targeted analysis, reinforcement, and outcome measurement. Completion alone is not effectiveness, ending measurement hides the gap, and uniform training may miss its cause.

Question 43 (CISM4-100)

Correct answer: D - Risk-based diligence, security duties, monitoring, supplier governance, continuity, and exit terms.

The service requires lifecycle governance from selection through exit, with obligations and evidence proportionate to the information risk. A single clause and reputation are insufficient, while information ownership remains with the accountable organization.

Question 44 (CISM4-101)

Correct answer: C - Assess aggregate business impact, concentration, resilience, contractual visibility, alternatives, and monitoring needs.

Individual reviews can miss enterprise concentration risk, so the shared dependency requires aggregate resilience analysis and governance. Prior approval is not conclusive, waiting is reactive, and the organization should oversee rather than operate the subcontractor.

Question 45 (CISM4-102)

Correct answer: D - Test data migration, continuity, access revocation, deletion evidence, and acceptance.

A tested exit plan must preserve usable information and its protection context while addressing continuity, access, and verifiable deletion. Immediate termination can strand data, indefinite duplication increases exposure, and verbal assurance is weak evidence.

Question 46 (CISM4-103)

Correct answer: D - Show outcome and risk trends, business impact, decisions, owners, and actions.

Decision-oriented reporting connects performance to objectives, risk, business impact, and accountability. Raw detail obscures priorities, withholding results impairs oversight, and security-only activity can hide enterprise dependencies.

Question 47 (CISM4-104)

Correct answer: C - Escalate through the defined path with evidence, impact, accountability, alternatives, and the decision required.

Exposure above tolerance and outside the manager's authority requires transparent escalation to the accountable decision body. Changing dates masks risk, security should not assume owner authority, and omission delays governance.

Question 48 (CISM4-105)

Correct answer: A - Define risk and operational outcomes, alternatives, decisions, and measures jointly.

Early, structured engagement supports a design that meets security and operational needs while clarifying accountability and measures. Unilateral implementation undermines ownership, supervisors may not hold all risk authority, and cancellation abandons the objective.

Question 49 (CISM4-106)

Correct answer: D - Assess workflows, ownership, risk, and capacity, then update the program.

Decentralization changes how the objective must be achieved and who is accountable, requiring coordinated program updates. Obsolete procedures and exclusion do not manage the new model, while waiting for failure is reactive.

Question 50 (CISM4-107)

Correct answer: B - Assess use cases, set supplier guardrails, run a pilot, and update controls.

Governed experimentation supports business learning while addressing safety, data, network, and supplier risks and feeding evidence into program improvement. Unrestricted use lacks safeguards, a permanent ban avoids proportionate assessment, and local rules fragment architecture and accountability.